

Full HTML report by Kobol Consulting

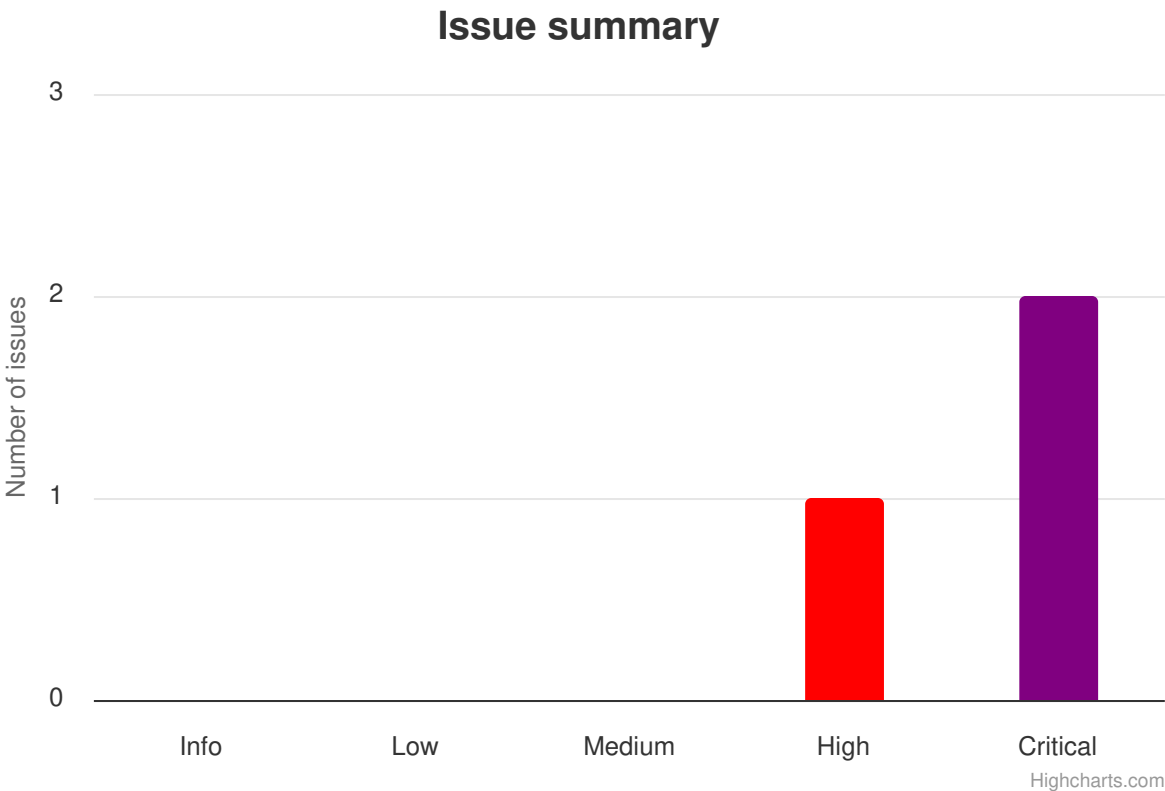
Informe de Auditoría de Seguridad: WackoPicko

Data: 23/02/2026

Este informe detalla as vulnerabilidades atopadas na aplicación de probas WackoPicko.

Summary of Findings

Issue	Risk	CVSSv4
Inxección de Código SQL na Autenticación (Login)	Critical	9.4
Inxección de Comandos Remotos no Sistema (Remote Code Execution)	Critical	9.8
Cross-Site Scripting (XSS) Almacenado no Guestbook	High	7.5



Detailed findings

Inxección de Código SQL na Autenticación (Login)

CVSSv4.BaseScore	9.4
Description	Detectouse unha vulnerabilidade de inxección SQL que permite manipular as consultas que a aplicación realiza á base de datos. Isto permite saltar os mecanismos de autenticación e acceder ao sistema sen coñecer o contrasinal. Impacto do Achado: Acceso non autorizado: Calquera persoa pode entrar na aplicación con privilexios de administrador simplemente manipulando o formulario de acceso. Exposición total da base de datos: Un atacante pode extraer toda a información almacenada (usuarios, correos, configuracións) ou incluso borrar as táboas completas. Fuga de credenciais: Permite obter os hashes dos contrasinais de todos os usuarios rexistrados na plataforma.

Solution	Para corrixir este fallo estrutural na aplicación, recoméndase: 1. Consultas Preparadas (Prepared Statements): Utilizar parametrización en todas as consultas SQL para que os datos do usuario nunca se executen como código. 2. Principio de Mínimo Privilexio: Configurar o usuario da base de datos para que só teña os permisos estritamente necesarios para o funcionamento da web.
References	https://owasp.org/www-community/attacks/SQL_Injection

Cross-Site Scripting (XSS) Almacenado no Guestbook

CVSSv4.BaseScore	7.5
Description	Identificouse un fallo de seguridade grave no Libro de Visitas que permite a un atacante “secuestrar” as sesións dos usuarios. Impacto Estratéxico: • Roubo de Contas: Un atacante pode acceder ás contas de clientes ou administradores sen necesidade de contrasinal. • Fraude e Phishing: O atacante pode modificar o que se ve na web para enganar aos usuarios e pedirilles datos bancarios ou persoais. • Dano á Marca: Se a web infecta os dispositivos dos visitantes, a reputación de WackoPicko veríase gravemente prexudicada e podería derivar en sancións legais por falta de protección de datos.
Solution	A solución require unha intervención técnica inmediata sobre o código da aplicación: 1. Validación de Datos: Bloquear a entrada de calquera carácter sospeitoso nos formularios. 2. Protección de Saída: Asegurar que o sistema “limpe” a información antes de mostrala no navegador, neutralizando calquera código malicioso.
References	https://www.aldeid.com/wiki/WackoPicko/Stored-XSS

Inxección de Comandos Remotos no Sistema (Remote Code Execution)

CVSSv4.BaseScore	9.8
Description	Identificouse unha vulnerabilidade crítica que permite executar ordes directamente no servidor que aloxa a aplicación WackoPicko. Isto supón un fallo total na barreira entre o usuario e o sistema operativo. Impacto do Achado: • Compromiso total do servidor: Un atacante pode tomar o control do sistema, borrar ficheiros ou ver calquera dato interno da aplicación. • Escalada de privilexios: Permite extraer información do ficheiro de configuración e obter claves de acceso do sistema. • Inestabilidade: O sistema pode ser apagado ou modificado de xeito que a aplicación deixe de funcionar permanentemente.
Solution	É necesario reescribir a funcionalidade afectada para evitar o uso de comandos de consola: 1. Evitar chamadas ao sistema: Non utilizar funcións que interactúen directamente coa terminal (como `exec` ou `system`). 2. Filtrado de caracteres especiais: Bloquear calquera entrada que conteña caracteres de encadeamento de comandos (como `;`, `&`, ` `). 3. Restrición de permisos: Asegurar que o usuario que executa a aplicación no servidor teña os permisos mínimos necesarios.
References	https://owasp.org/www-community/attacks/Command_Injection
